

RedScope Capstone: Red-Team Assessment

Lab-only red-team assessment of DVWA, OWASP Juice Shop, Metasploitable 2, and Adversarial Machine Learning

- Shamanth R Singh
- Ajith Mohan
- Saiteja Kacham
- Madhurjya Deka

Billion Connections - Expanding Attack Surface

Invisible perimeter has moved — it's everywhere your signals reach.

63%

experienced an IoT-related
incident in the last year

Attack Proximity

Adversaries can strike from outside your perim

Made with GAMMA

Assessment at a Glance

Objective

Assess the security posture of an isolated penetration testing laboratory using realistic attack techniques.

Lab Environment

- DVWA
- OWASP Juice Shop
- Metasploitable 2
- Kali Linux

Key Findings

- SQL Injection
- FTP information disclosure
- Unauthenticated bind shell
- Successful privilege compromise
- ML detection evasion

Bottom Line

Multiple low-complexity weaknesses combined into a realistic end-to-end compromise.

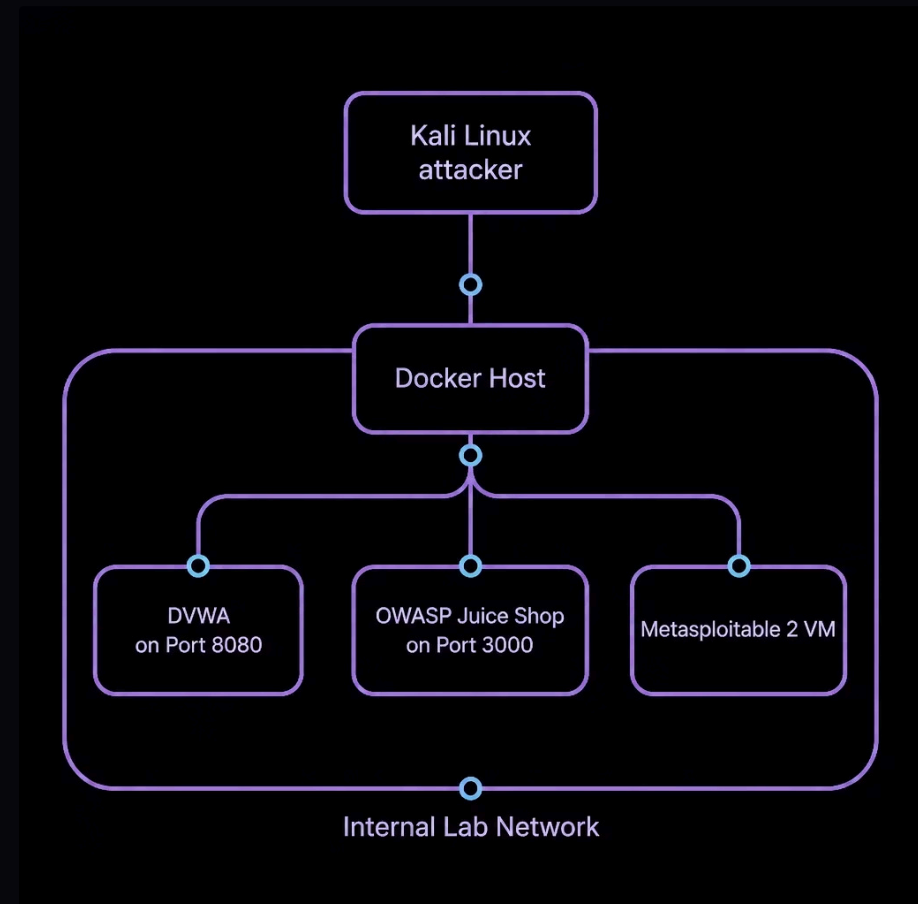
Lab Architecture & Authorized Scope

Authorized Targets

- DVWA — Port 8080
- OWASP Juice Shop — Port 3000
- Metasploitable 2 VM
- Kali Linux attacker

Out of Scope

- Internet-facing systems
- Denial-of-Service attacks
- Persistence or data destruction
- Real users or production data



METHODOLOGY

Engagement Workflow



Planning



Reconnaissance



Scanning



Vulnerability Assessment



Exploitation



Evidence Collection

Key observations surfaced during reconnaissance and scanning: legacy services exposed, weak web application configuration, FTP directory disclosure, and multiple distinct attack surfaces identified across all targets.

Web Application Findings

How to install Aikido Firewall

Select the stack you are using and follow the instructions to install the Aikido Firewall.

[View on GitHub](#)

Language

JavaScript ▾

Firewall runs server-side, we only support Node.js at this moment.

Installation

npm ▾

```
npm install @aikidosec/firewall
```

Implementation

Express ▾

```
// Include this before any other code or imports
require('@aikidosec/firewall');

const express = require('express');

const app = express();

// ...
```

Token

Add AIKIDO_TOKEN to your environment.

```
AIKIDO_TOKEN=AIK_RUNTIME_...
AIKIDO_BLOCKING=false
```

Token Generation

Add this token to the environment variables of your app under AIKIDO_TOKEN.

Generate Token

Close

DVWA — SQL Injection

Unsafe input accepted without parameterized queries, enabling direct database interaction.

- Authentication bypass
- Full database disclosure
- Sensitive information exposure

OWASP Juice Shop — FTP Directory Exposure

Sensitive files accessible through an exposed directory listing with weak access controls.

- Information disclosure
- Weak access controls

NETWORK EXPLOITATION

Metasploitable 2 — Unauthenticated Bind Shell

Target

Metasploitable 2

Port

TCP 1524

Finding

Successful shell access without authentication

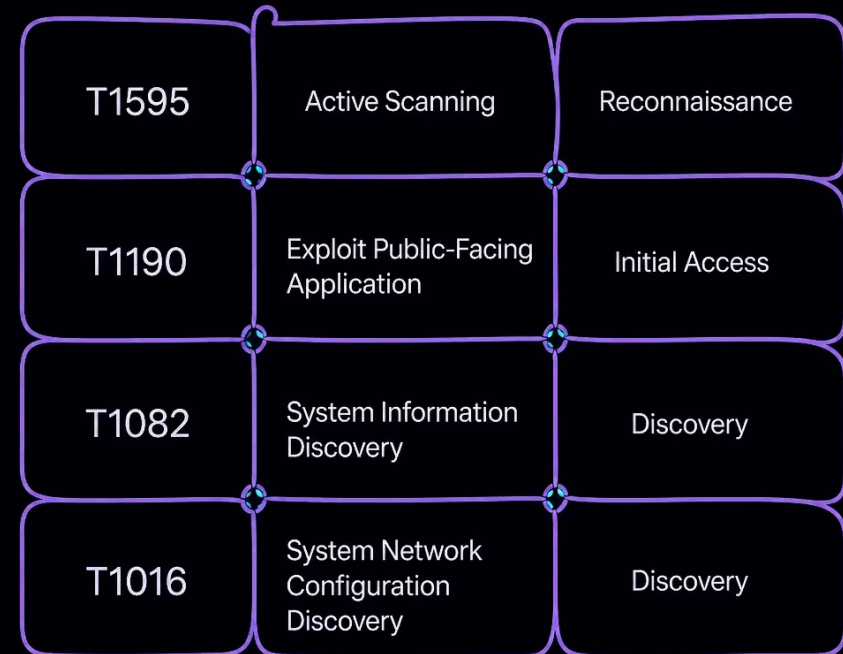
Impact

Root-level compromise — complete host access and full system control

Activities & MITRE ATT&CK Mapping

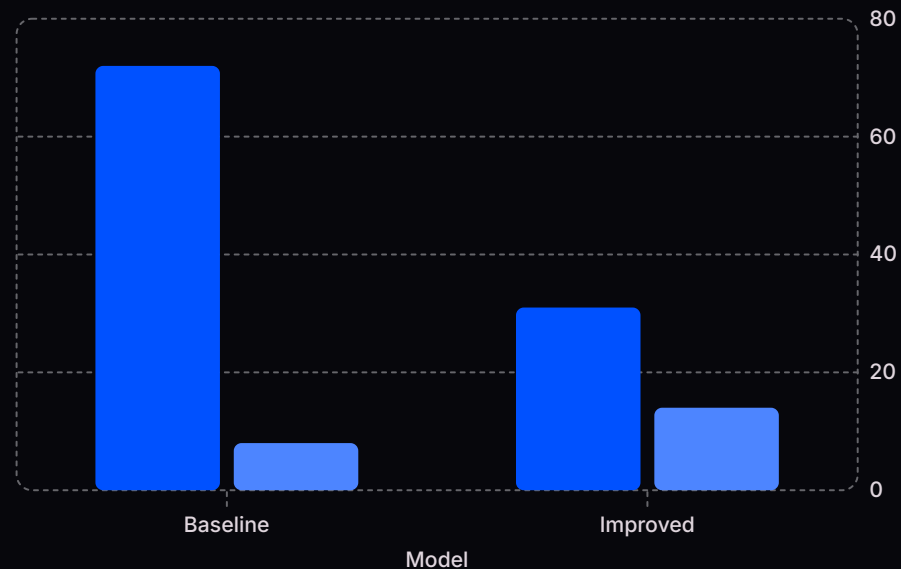
Post-Exploitation Activities

- Host enumeration
- User identification
- Network configuration discovery
- Service verification



ML Detector — Baseline vs. Improved

■ Evasion Rate (%) ■ False Positive Rate (%)



Experiment Flow

01

Baseline detector deployed

02

Attack modifications applied

03

Baseline detection bypassed

04

Improved model using character n-grams



Key Lesson: Small datasets and narrow feature engineering are vulnerable to adversarial manipulation.

Business Impact & Recommendations

Risks Identified

- Unauthorized access via SQL injection
- Sensitive data exposure through FTP
- Root-level system compromise
- Internal information disclosure
- Expanded attack surface from legacy services

Mitigations

- Parameterize all SQL queries
- Restrict directory listing and FTP access
- Remove or harden unnecessary services
- Enforce authentication on all endpoints
- Apply security patches and updates
- Implement network segmentation
- Deploy layered detection and continuous monitoring

CLOSING REMARKS

Team Contributions & Key Takeaway

Shamanth R Singh

Project coordination, web exploitation, presentation integration

Ajith Mohan

Network exploitation and post-exploitation

Saiteja Kacham

Machine learning detector and adversarial evaluation

Madhurjya Deka

Risk assessment and remediation strategy

"Security failures rarely occur in isolation. Individually minor weaknesses can combine into a complete compromise. Layered defenses, secure development practices, and continuous monitoring are essential to reducing organizational risk."